

ACTIVIDAD 8: TRAVERSAL SEQUENCES BLOCKED WITH ABSOLUTE PATH BYPASS

PROGRAMACION WAP

JESÚS ISRAEL MARTÍNEZ ESCOBEDO

Contenido

1. NIVEL.....	2
2. TIPO DE EXPLOTACIÓN.....	2
3. OBJETIVO DEL LABORATORIO	2
4. EXPLICACIÓN TÉCNICA DE LA VULNERABILIDAD	2
5. PROCEDIMIENTO PASO A PASO	3
5.1 Acceso al laboratorio	3
5.2 Identificación de la solicitud	3
5.3 Envío de la solicitud a Repeater.....	3
5.4 Modificación del parámetro vulnerable	3
5.5 Envío de la solicitud modificada	3
5.6 Análisis de la respuesta.....	4
5.7 Confirmación de la resolución	4
6. EVIDENCIAS.....	4
7. EXPLICACIÓN DEL PAYLOAD	8
8. MITIGACIÓN RECOMENDADA.....	9
CONCLUSIÓN	9

1. NIVEL

Practitioner

2. TIPO DE EXPLOTACIÓN

File Path Traversal mediante bypass de secuencias de recorrido utilizando una ruta absoluta.

3. OBJETIVO DEL LABORATORIO

El objetivo del laboratorio es identificar y explotar una vulnerabilidad de File Path Traversal presente en la funcionalidad encargada de mostrar las imágenes de los productos.

La aplicación implementa un mecanismo que bloquea las secuencias tradicionales de recorrido de directorios, como ../. Sin embargo, el valor proporcionado mediante el parámetro filename continúa siendo procesado por la aplicación como una ruta de archivo.

La finalidad específica del laboratorio consiste en utilizar una ruta absoluta para evadir la restricción existente y recuperar el contenido del archivo:

/etc/passwd

4. EXPLICACIÓN TÉCNICA DE LA VULNERABILIDAD

La vulnerabilidad de File Path Traversal ocurre cuando una aplicación permite que datos controlados por el usuario influyan directamente en la ubicación de un archivo que será procesado o recuperado por el servidor.

En este laboratorio, la aplicación utiliza el endpoint /image para recuperar las imágenes asociadas a los productos. El archivo solicitado se determina mediante el parámetro filename.

La solicitud original identificada durante la práctica fue:

GET /image?filename=36.jpg HTTP/2

El valor 36.jpg corresponde a una imagen de producto solicitada normalmente por la aplicación.

El mecanismo de protección implementado por el laboratorio bloquea las secuencias de recorrido de directorios, por lo que un intento tradicional utilizando valores como ../../../etc/passwd no constituye el método de explotación esperado.

Sin embargo, la aplicación continúa aceptando una ruta absoluta proporcionada directamente mediante el parámetro filename. Debido a esto, fue posible sustituir el nombre de la imagen por:

/etc/passwd

La aplicación procesó esta ruta y devolvió el contenido del archivo solicitado. Esto demuestra que el filtro existente únicamente evita determinadas secuencias de traversal, pero no restringe correctamente el destino final del archivo solicitado.

5. PROCEDIMIENTO PASO A PASO

5.1 Acceso al laboratorio

Se accedió al laboratorio correspondiente de PortSwigger Web Security Academy y se ingresó a uno de los productos disponibles para identificar la solicitud utilizada para recuperar su imagen.

5.2 Identificación de la solicitud

Mediante Burp Suite, específicamente en Proxy → HTTP history, se identificó la solicitud correspondiente a la imagen del producto.

La solicitud original observada fue:

```
GET /image?filename=36.jpg HTTP/2
```

El parámetro de interés fue filename, debido a que su valor determina el archivo que será recuperado por el servidor.

5.3 Envío de la solicitud a Repeater

La solicitud identificada fue enviada a Burp Suite Repeater con la finalidad de poder modificar manualmente el valor del parámetro filename y analizar el comportamiento de la aplicación.

5.4 Modificación del parámetro vulnerable

Se sustituyó el valor original del parámetro:

```
filename=36.jpg
```

por:

```
filename=/etc/passwd
```

La solicitud modificada quedó de la siguiente manera:

```
GET /image?filename=/etc/passwd HTTP/2
```

No fue necesario utilizar secuencias . . /, ya que el objetivo del laboratorio consiste en evadir esta restricción mediante el uso de una ruta absoluta.

5.5 Envío de la solicitud modificada

La solicitud modificada fue enviada desde Burp Suite Repeater mediante la opción Send.

5.6 Análisis de la respuesta

La aplicación respondió correctamente con un código:

HTTP/2 200 OK

La respuesta contenía el contenido del archivo `/etc/passwd`, incluyendo entradas correspondientes a diferentes cuentas existentes en el sistema.

Entre los datos observados se encontraban entradas como:

`root:x:0:0:root:/root:/bin/bash`

y:

`peter:x:12001:12001::/home/peter:/bin/bash`

La respuesta confirmó que el servidor procesó la ruta absoluta proporcionada mediante el parámetro `filename`.

5.7 Confirmación de la resolución

Después de realizar la solicitud modificada, se regresó al laboratorio en Web Security Academy y se verificó que la plataforma mostrara la confirmación:

Lab Solved

Con esto se confirmó que el objetivo del laboratorio había sido alcanzado correctamente.

6. EVIDENCIAS

Figura 1. Solicitud HTTP original.

Descripción:

La captura muestra la solicitud HTTP generada por la aplicación para recuperar una imagen de producto. El parámetro `filename` contiene originalmente el valor `36.jpg`, correspondiente al recurso solicitado normalmente por la aplicación.

Evidencia:

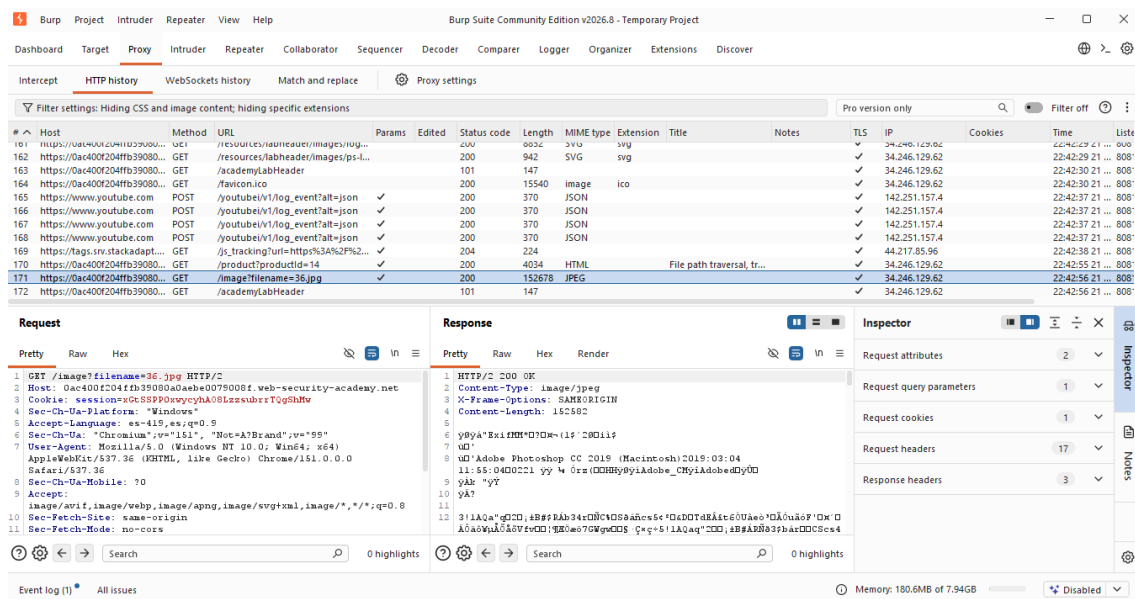


Figura 2. Payload utilizado

Descripción:

La captura muestra la solicitud modificada mediante Burp Suite. El valor original del parámetro filename fue sustituido por la ruta absoluta /etc/passwd.

Esta modificación permite comprobar si la aplicación restringe el acceso exclusivamente al directorio destinado a las imágenes o si procesa directamente una ruta absoluta proporcionada por el usuario.

Evidencia:

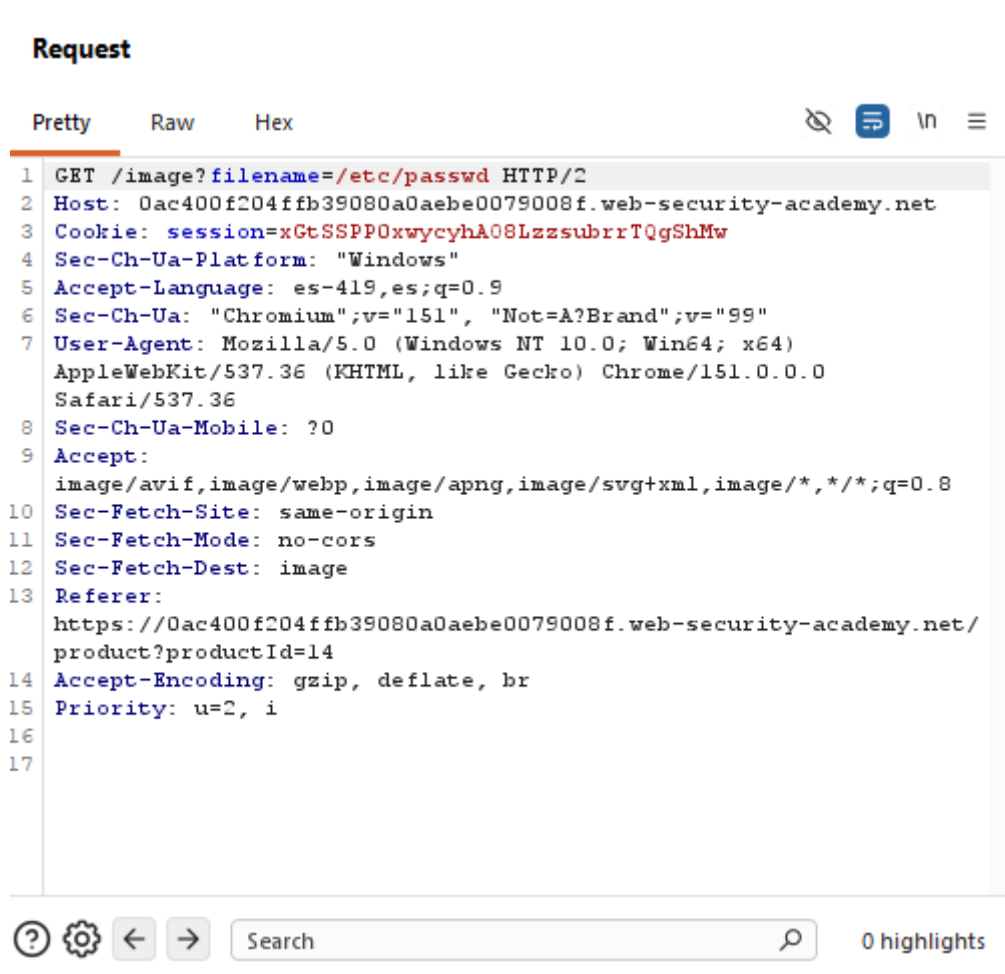


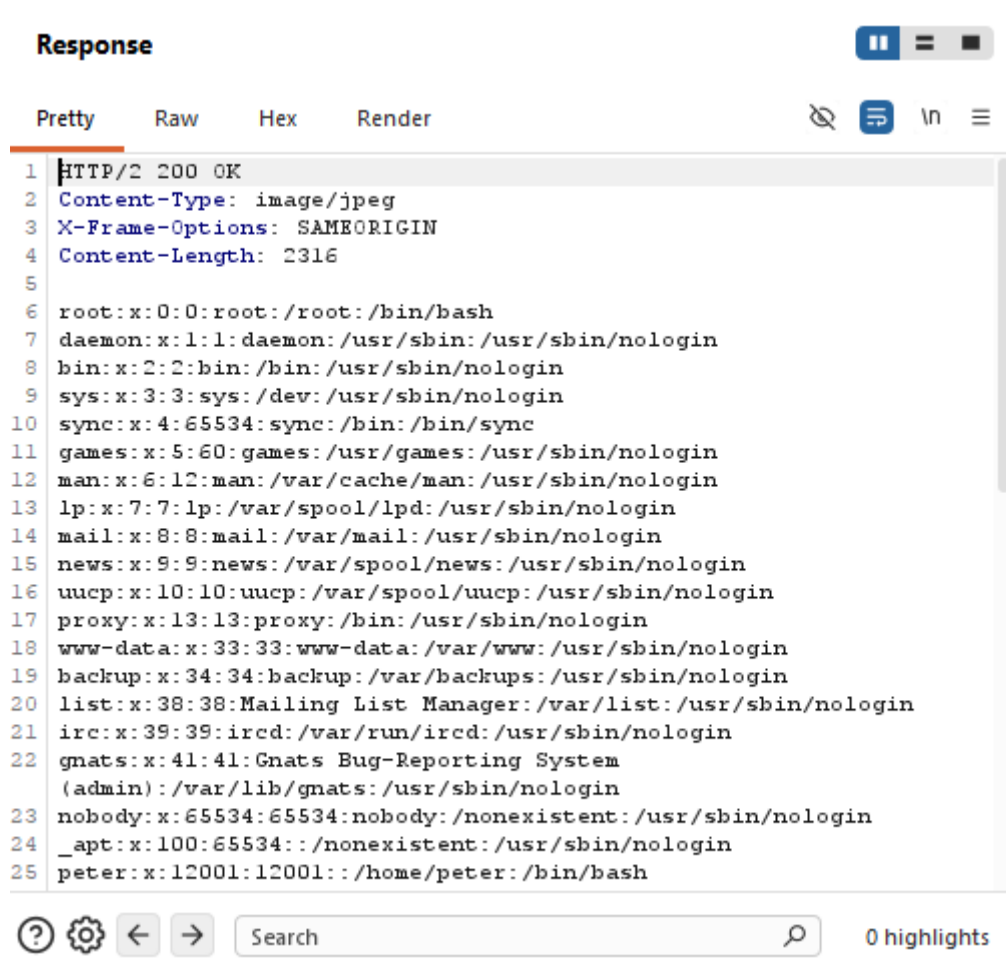
Figura 3. Respuesta vulnerable

Descripción:

La captura muestra la respuesta obtenida después de enviar la solicitud modificada. El servidor respondió con HTTP/2 200 OK y devolvió el contenido del archivo `/etc/passwd`.

La presencia del contenido del archivo confirma que la aplicación permitió acceder a un recurso ubicado fuera del directorio destinado originalmente para las imágenes.

Evidencia:



```
1 HTTP/2 200 OK
2 Content-Type: image/jpeg
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 2316
5
6 root:x:0:0:root:/root:/bin/bash
7 daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
8 bin:x:2:2:bin:/bin:/usr/sbin/nologin
9 sys:x:3:3:sys:/dev:/usr/sbin/nologin
10 sync:x:4:65534:sync:/bin:/bin/sync
11 games:x:5:60:games:/usr/games:/usr/sbin/nologin
12 man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
13 lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
14 mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
15 news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
16 uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
17 proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
18 www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
19 backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
20 list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
21 irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
22 gnats:x:41:41:Gnats Bug-Reporting System
  (admin):/var/lib/gnats:/usr/sbin/nologin
23 nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
24 _apt:x:100:65534::/nonexistent:/usr/sbin/nologin
25 peter:x:12001:12001:/home/peter:/bin/bash
```

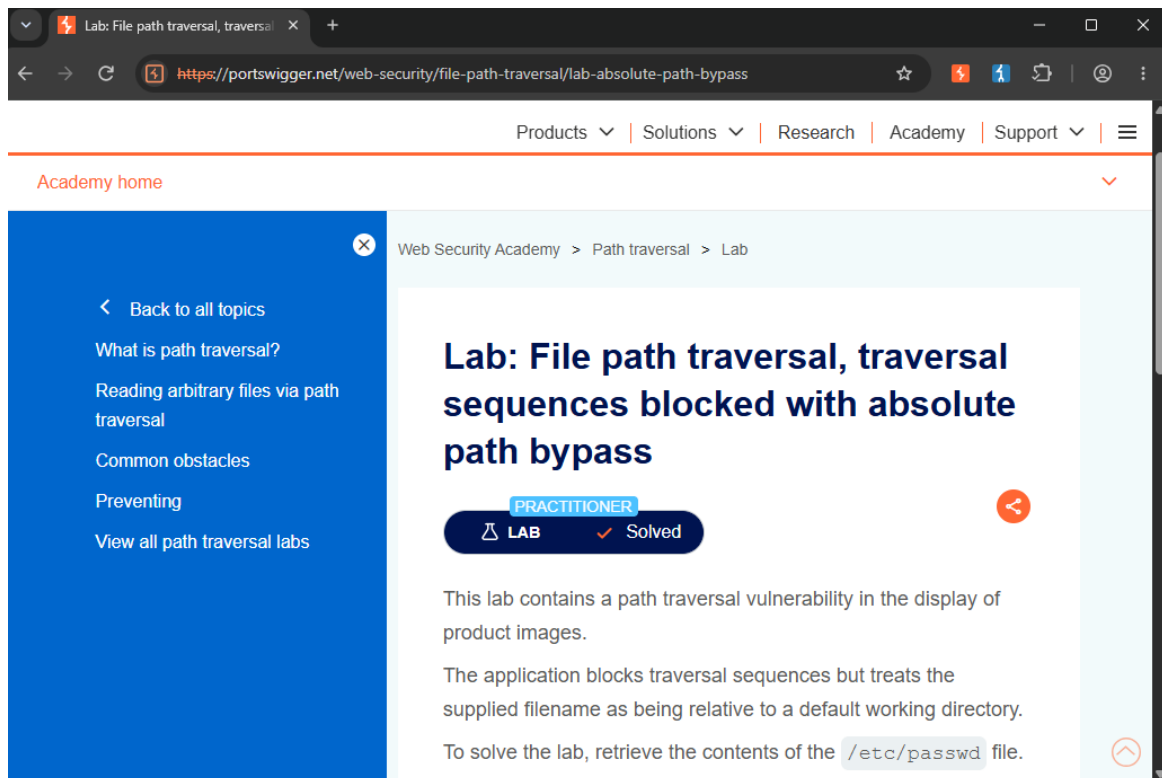
Figura 4. Confirmación de Lab Solved

Descripción:

La captura muestra la confirmación proporcionada por PortSwigger Web Security Academy después de realizar correctamente la explotación.

La plataforma identifica el laboratorio como **Lab Solved**, confirmando que el objetivo fue alcanzado.

Evidencia:



7. EXPLICACIÓN DEL PAYLOAD

El payload utilizado fue:

`/etc/passwd`

A diferencia de un ataque tradicional de Path Traversal, en este laboratorio no fue necesario utilizar secuencias como `../` para desplazarse entre directorios.

La aplicación bloquea las secuencias de recorrido de directorios, por lo que el enfoque consiste en proporcionar directamente una **ruta absoluta** correspondiente al archivo que se desea recuperar.

El valor `/etc/passwd` representa la ubicación absoluta del archivo dentro del sistema de archivos de sistemas Linux y Unix. Al introducirlo directamente en el parámetro `filename`, la aplicación lo procesa como la ubicación del recurso que debe recuperar.

La vulnerabilidad se produce porque el mecanismo de protección no garantiza que el archivo solicitado permanezca dentro del directorio destinado a las imágenes. En consecuencia, aunque las secuencias de traversal estén bloqueadas, la aplicación sigue permitiendo que el usuario determine directamente una ruta fuera del directorio esperado.

La respuesta HTTP/2 200 OK acompañada del contenido de `/etc/passwd` confirmó que el bypass fue exitoso.

8. MITIGACIÓN RECOMENDADA

Para evitar vulnerabilidades de File Path Traversal, la aplicación debe impedir que los datos proporcionados por el usuario determinen arbitrariamente la ubicación de los archivos que serán procesados por el servidor.

Una medida recomendada consiste en utilizar una lista controlada de nombres o identificadores de archivos en lugar de aceptar directamente rutas proporcionadas por el cliente.

También debe validarse la ruta resultante y garantizar que permanezca dentro del directorio autorizado para almacenar y recuperar las imágenes. La validación debe contemplar tanto secuencias de recorrido como rutas absolutas y otras formas de manipulación de rutas.

Cuando sea posible, una alternativa más segura consiste en asociar un identificador controlado por la aplicación con cada imagen y utilizar dicho identificador para localizar internamente el archivo, evitando que el usuario proporcione directamente una ruta del sistema de archivos.

CONCLUSIÓN

El laboratorio permitió demostrar de manera práctica una vulnerabilidad de File Path Traversal que puede ser explotada mediante un bypass de ruta absoluta.

La aplicación contaba con una restricción destinada a bloquear las secuencias tradicionales de recorrido de directorios, pero dicha protección no impedía que el usuario proporcionara directamente una ruta absoluta mediante el parámetro filename.

Al modificar la solicitud de:

GET /image?filename=36.jpg HTTP/2 a: GET /image?filename=/etc/passwd HTTP/2

el servidor procesó la ruta proporcionada y devolvió el contenido del archivo /etc/passwd.

La respuesta obtenida y la posterior confirmación de **Lab Solved** demostraron que la protección implementada era insuficiente para controlar correctamente el acceso a los archivos.

Este ejercicio demuestra que una defensa contra Path Traversal no debe limitarse únicamente a bloquear determinadas secuencias como ../. Es necesario controlar de manera integral las rutas proporcionadas por el usuario y garantizar que los recursos solicitados permanezcan dentro de los directorios autorizados por la aplicación.